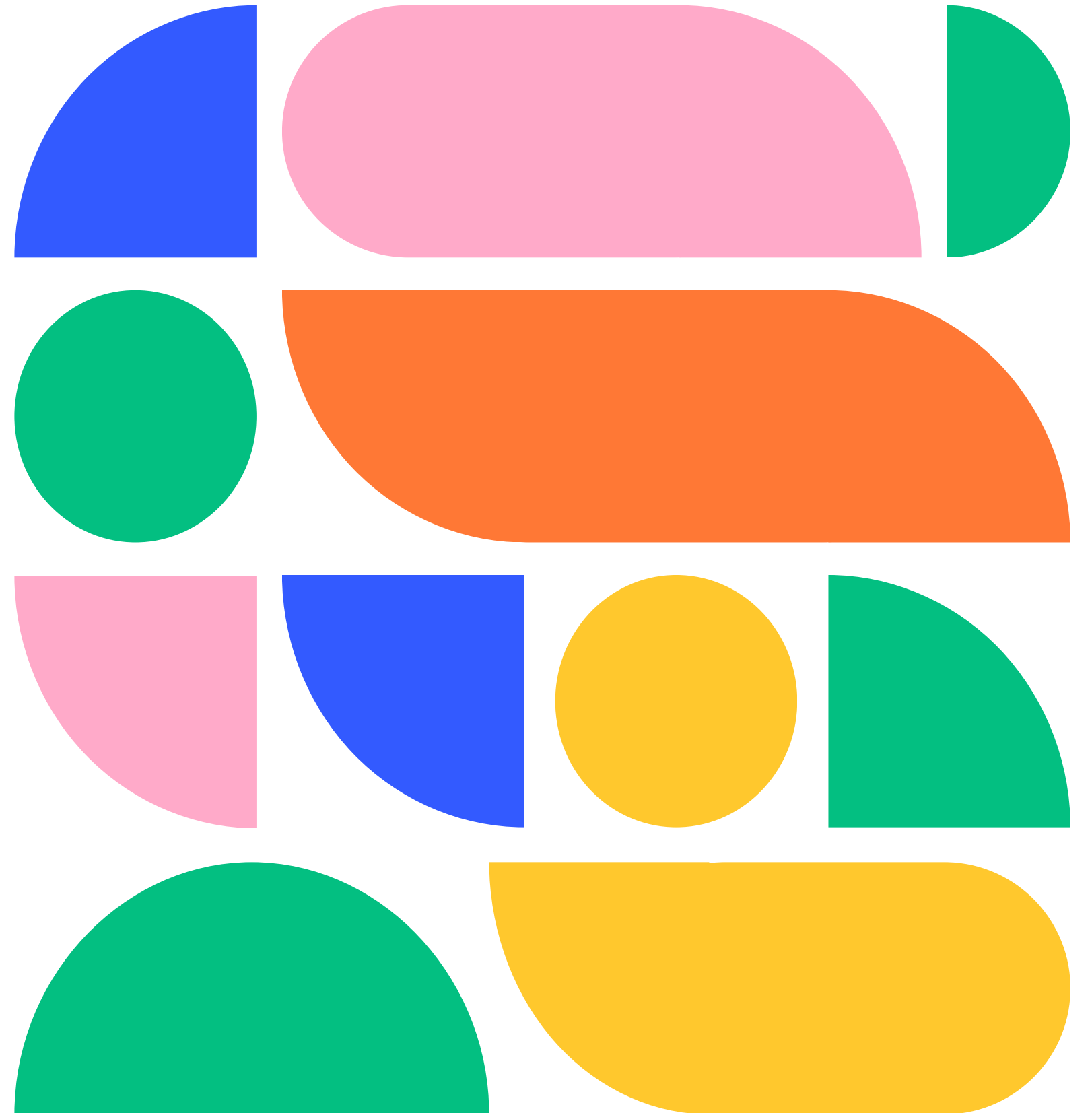


Vulnerability Assessment Report Target: demo.testfire.net

Presented by
Munnuru Akshitha



Executive Summary

This report summarizes a read-only security assessment conducted on demo.testfire.net (Altoro Mutual demo banking site). The assessment identified 7 security concerns, ranging from Medium to High risk, primarily related to unencrypted data transmission, exposed administrative resources, and missing security configurations. No exploitation, login attempts, or destructive testing was performed. All findings are based on passive observation and publicly available information. Addressing the High-risk items — particularly the unencrypted login page and exposed API documentation — should be the top priority.



Risk Identification Matrix

01

High Risk Findings

- Login page transmits credentials over unencrypted HTTP
- API documentation publicly exposes admin/financial endpoints

02

Low-Medium Risk Findings

- Server Status Check diagnostic tool publicly accessible
- Content pages show outdated maintenance dates (2004-2006)

03

Medium Risk Findings

- Site runs on HTTP by default, not HTTPS
- Missing critical security headers (CSP, X-Frame-Options, HSTS)
- Multiple open ports with identifiable server software (Apache-Coyote/1.1)



Mitigation Action Plan

Based on the assessment findings, the following actions are recommended to reduce risk exposure, prioritized by severity.



01

Action A: Secure Data in Transit

Enforce HTTPS site-wide, redirect all HTTP traffic, and enable HSTS. This directly addresses the unencrypted login page — the most critical finding.

02

Action B: Restrict Public Exposure

Remove public access to API documentation and the Server Status Check tool. Restrict these to internal/authenticated users only.

03

Action C: Harden Server Configuration

Add missing security headers (CSP, X-Frame-Options, HSTS), close unnecessary open ports, and suppress server version banners.